ЕЦП RSA

Важливою компонентою Протоколу електронного голосування є акт засвідчення достовірності, автентичності ОІД - об'єкта інформаційної діяльності (бланка, документа, бюлетеня) чи його приналежності певному СІД – суб'єкту інформаційної діяльності (виборцю, кандидату, виборчій комісії ВК; обчислювальному процесу, автономно виконуваному у обчислювальному пристрої, тощо …).

Як ми бачили раніше, акт засвідчення достовірності, автентичності чи приналежності виконується суб'єктом СІД шляхом постановки власного підпису на об'єкт ОІД (бланк, документ, бюлетень тощо).

У системах електронного голосування створюються, беруться на облік, функціонують, циркулюють у комунікаційних каналах електронні ОІД (бланки, документи, бюлетені), які потребують відповідних інструментів виконання акту засвідчення достовірності, автентичності їх, чи їх приналежності певному

власнику – електронних засобів постановки та верифікації підпису.

Ці засоби мають назву «електронний цифровий підпис» (ЕЦП). За сутністю, це є алгоритми ЕЦП, у формі певних процедур.

Найбільш розповсюдженими алгоритмами ЕЦП наразі є алгоритми:

- RSA у режимі засвідчення OID приватним ключем;

- схема ElGamal постановки і верифікації ЕЦП на OID.

ПІДПИС ПОВІДОМЛЕННЯ M НА БАЗІ КРИПТОГРАФІЇ З ВІДКРИТИМИ КЛЮЧАМИ

Змоделюємо сценарій ЕЦП на базі алгоритму RSA.

Нагадаємо, RSA знаходиться у вжитку ≈ 40 років. Докладно алгоритм RSA розглянуто у попередніх лекціях Лк5, Лк6, Лк7, Лк7.1. Пам'ятаємо, що RSA ефективний при опрацюванні коротких повідомлень, чи хеш-значень великих текстів. Хоча, зазвичай, обмежень на його використання не накладають.

Підпис документа (не сліпий!) за допомогою асиметричного криптоалгоритма RSA.

Актори: користувачі A, B, C, D, E, F … незахищеного спільного середовища доступу.

Сценарій ЕЦП1: Користувач A збирається підписати ОІД, цифрове повідомлення "m" і надіслати його неконфіденційно до Отримувача F. Вимагається лише засвідчити перед F достовірність, автентичність чи приналежність "m" Відправникові A. За цим сценарієм, не вимагається захист конфіденційності "m" .

Протокол: користувачі A, B, C, D, E, F, … незахищеного спільного середовища доступу попередньо отримують власні пари ключів: секретний $d_j = K_{prj}$ та публічний $e_j = K_{pbj}$, де j = A, B, C, D, E, F, …

Вони отримують ключі або самостійно, за процедурою обчислення пари ключів RSA, або ж – від третьої довіреної сторони, наприклад, засвідчувальний центр сертифікатів відкритих ключів (Certification Authority Center).

Для постановки ЕЦП, RSA вимагає від відправника A зашифрувати документ m на власному приватному ключі da. Перевірити підпис може будь-хто, навіть криптоаналітик чи зловмисник, у кого є відкритий ключ ea, математично зв'язаний із da.

Наприклад, користувачі A та F

A			F			OID	
na	da	ea	nf	df	ef	m	
221	67	43	221	175	79	92	

Протокол ЕЦП1 наступний:

1. A зашифровує m власним приватним ключем da.

$$ca \equiv m^{da} \bmod na = 92^{67} \bmod 221 = 105.$$

2. A надсилає m і криптограму ca безпосередньо до F.

$$(m;\ ca) = (92;\ 105).$$

3. F розшифровує документ m публічним ключем ea Відправника A.

$$m^* \equiv ca^{ea} \bmod na = 105^{43} \bmod 221 = 92.$$

4. F порівнює: m = m* ?

Якщо дані співпали, то ЕЦП верифіковано. ОІД m є достовірним, автентичним і належить саме Відправникові A, оскільки тільки A володіє власним приватним ключем da і ні у кого більше немає такого ключа.

Тільки A міг створити криптограму ca = 105 на da .

Цей факт засвідчено співпадінням m = m* = 92 після розшифрування ca = 105 на публічному ключі ea .

Супутньо засвідчено цілісність (integrity) ОІД m, його неушкодженість, відсутність його підробки, імітації чи фальсифікації.

Але! У цьому протоколі підпису не забезпечено конфіденційність m. Існують сценарії, де так потрібно робити, з метою економії ресурсів, наприклад, коли ОІД не несе в собі критично важливої інформації.

Цей Протокол ефективніше попередніх. Немає потреби в участі Посередника ні для підпису M, ні для верифікації його, ні для розв'язку суперечок.

Якщо, наприклад, F не досяг успіху на кроці 4, то підпис документа M не верифіковано і F сам приймає рішення та відкидає M, як недостовірне, не аутентичне повідомлення.

Необов'язково передавати m у п.2, достатньо передати **ca**.

ЕЦП RSA з захистом конфіденційності OID m

Актори: користувачі A, B, C, D, E, F ... незахищеного спільного середовища доступу.

Сценарій ЕЦП2: Користувач A збирається підписати OID, цифрове повідомлення "m" і надіслати його конфіденційно до Отримувача F. Вимагається не лише засвідчити перед F достовірність, автентичність чи приналежність "m" Відправникові A, а ще й

забезпечити конфіденційність "m" при комунікації та зберіганні у сховищах даних.

Протокол: користувачі A, B, C, D, E, F, ... незахищеного спільного середовища доступу попередньо отримують власні пари ключів: секретний $d_j = K_{prj}$ та публічний $e_j = K_{pbj}$, де j = A, B, C, D, E, F, ... Вважаємо, що $n_a = n_j$.

Вони отримують ключі або самостійно, за процедурою обчислення ключів RSA, або ж – від третьої довіреної сторони: засвідчувальний центр сертифікатів відкритих ключів (Certification Authority Center). Вважаємо, що $n_a = n_j$. і вони мають однакові алфавіти.

Для постановки ЕЦП RSA вимагає від відправника A зашифрувати документ m на власному приватному ключі d_a. Перевірити підпис може будь-хто, навіть криптоаналітик чи зловмисник, у якого є відкритий ключ e_a, математично зв'язаний із d_a. Всі ці суб'єкти можуть і прочитати текст m після дешифрування на публічному ключі Відправника A.

Тому, для захисту конфіденційності OID m, протокол потребує додаткової дії: зашифрування на публічному ключі e_f Отримувача F. Розшифрувати криптограму

тоді зможе тільки Отримувач F, і тільки він, на власному приватному ключі df.

Конфіденційність тут можна додати наступним чином:

1. A зашифровує m власним приватним ключем da=67.

Ставить свій ЕЦП, власний підпис на m

$$ca \equiv m^{da} \bmod na = 92^{67} \bmod 221 = 105.$$

2. A зашифровує ca = 105 додатково відкритим ключем отримувача ef =79 і надсилає caf до F (конфіденційність).

$$caf \equiv ca^{ef} \bmod nf = 105^{79} \bmod 221 = 40.$$

3. F розшифровує caf на власному приватному df =175

$$ca \equiv caf^{df} \bmod nf = 40^{175} \bmod 221 = 105.$$

4. F розшифровує ca на публічному ключі ea = 43

$$m^* \equiv ca^{ea} \bmod na = 105^{43} \bmod 221 = 92.$$

І таким чином дізнається повідомлення m* = 92.

Вважаємо, що обчислення виконуються безпомилково, а у каналі комунікації застосовано завадостійкі коди.

З детального розгляду алгоритма RSA вам відомо, що користувачі j = A, B, C, D, E, F … можуть отримати різні, неоднакові значення потужності алфавіту n_j.

Це не викликає жодних проблем у двох режимах RSA:

1. Забезпечення тільки конфіденційності m;

2. Забезпечення тільки достовірності, автентичності m.

У режимі RSA 1. Забезпечення конфіденційності m використовуються тільки ключі Отримувача j :

- ключ зашифрування (e_j ; n_j), два числа, та

- ключ розшифрування (d_j ; n_j), два числа.

Модуль n_j у цьому режимі однаковий для обох користувачів.

У режимі 2. Забезпечення достовірності, автентичності ОІД m , використовуються тільки ключі Відправника S:

- ключ зашифрування (d_s ; n_s), два числа, та

- ключ розшифрування (e_s ; n_s), два числа.

Модуль ns у цьому режимі теж однаковий для обох користувачів.

[Приклади наведено у минулій лекції з RSA]

Нюанси можуть виникнути у Режимі 3 RSA Забезпечення достовірності, автентичності та конфіденційності повідомлення m разом.

[Приклад наведено у Exel демонстраторі Лк6.1 до лекції 6, і нижче]

Певна свобода у параметрі nj RSA для різних користувачів-**а**кторів викликає потребу узгоджувати порядок дій в Режимі RSA 3, залежно від величини nj.

У RSA 3. Забезпечення достовірності, автентичності та конфіденційності повідомлення m використовуються ключі **двох** **а**кторів :

Відправника S :

- ключ зашифрування (d_s ; n_s), два числа, та
- ключ розшифрування (e_s ; n_s), два числа.

Отримувача j :

- ключ зашифрування (e_j ; n_j), два числа, та
- ключ розшифрування (d_j ; n_j), два числа.

Модулі n_j та n_s у цьому режимі можуть бути як однаковими, так і не однаковими: $n_j \neq n_s$.

Узгодження порядку дій у Режимі RSA 3 полягає у наступному:

Відправник S (підписант ЕЦП) має порівняти два значення модулів n_s і n_j та виконати першим крок Протоколу RSA ЕЦП+конфіденційність, який вимагає застосування меншого значення модуля n із двох.

Потім виконати крок Протоколу RSA ЕЦП + конфіденційність за більшим модулем n із двох.

Отриману подвійну криптограму («подвійний запечатаний е-конверт») передає Отримувачеві j.

Отримувач j має виконати дії у зворотному порядку:
- перше розшифрування («розпечатати зовнішній е-конверт») за більшим із двох модулем n;
- друге розшифрування («розпечатати внутрішній е-конверт») за меншим із двох модулем n.

Це дозволить уникнути колізії виходу за межі модуля.

За умови $n_j = n_s$, порядок дій може бути різним, але Відправникові та Отримувачеві слід домовитись, який крок робити першим, а який другим:

- підпис m Відправником на власному d_s;

- подальше зашифрування ним на публічному ключі e_j Отримувача.

Чи ці два кроки виконати навпаки.

Головне, щоби Отримувач **j** виконав свої кроки у зворотному порядку.

[Приклад за умови $n_j = n_s$ наведено вище на стор. 8]

Обговоримо властивості ЕЦП RSA.

Протокол RSA ЕЦП, три Режими (варіанти), відповідає всім вимогам підпису ОІД m, наведеним вище:

1. Підпис m є достовірним. Якщо B розшифровує криптограму відкритим ключем A (e_a; n_a), він знає, що підписати m міг тільки A власним приватним ключем (d_a; n_a). Ніхто інший не має такого ключа, тому не міг утворити такий ЕЦП.

2. Підпис є непідробний. Бо тільки А знає свій приватний ключ (d_a; n_a) і ніхто інший (за умови виключення компрометації ключа d_a) і тільки А міг поставити такий підпис на m. Підробити ЕЦП зловмисник не здатен за прийнятний обсяг часу.

3. Цей підпис не можна використати повторно. ЕЦП є функцією аргументу «документ m» і не може бути перенесений на інший документ, з іншим значенням його числового образу m_s. Перевірка виявить факт.

4. Підписаний документ не можна змінити. Після будь-якої зміни документа m (числ. образ m), підпис не буде верифікуватися на публічному ключі e_a підписанта А.

5. Підписант А не зможе відректися від підпису на m. Верифікатор В може сам перевірити дійсність підпису на документі m з допомогою (e_a; n_a) публічного ключа А, наприклад, із Сертифіката відкритого ключа А.

Далі розташовано додатковий матеріал:

(для зацікавлених студентів з предмета ПАЕГ)

Приклади ЕЦП RSA + конфіденційність при модулях користувачів $n_s \neq n_j$, що не співпадають

Приклад: ЕЦП + конфіденційність повідомлення m.

RSA ЕЦП3. Користувачі A та B, $n_a \neq n_b$:

A			B			ОІД	Напрямок
na	da	ea	nb	db	eb	m	передачі
667	41	601	391	95	63	92	A→B

Протокол RSA ЕЦП3 при $n_a \neq n_b$ наступний:

Відправник A порівнює n_a та n_b: $n_a > n_b$, 667 > 391.

1. Тому він обирає першим крок, що виконується за меншим модулем n_b = 391 за логікою RSA протоколу. Оскільки модулю n_b = 391 належить пара ключів Отримувача B (db; eb=63), а Відправникові відомі лише публічні дані (eb=63; nb=391) і значення db є йому невідомим, то Відправникові лишається єдина дія - це крок забезпечення конфіденційності m=92 на публічному ключі Отримувача B eb=63; nb=391 :

$c_1 \equiv m^{e_b} \bmod n_b = 92^{63} \bmod 391 = 345.$

2. А зашифровує c_1 власним приватним ключем $d_a=41$. І ставить тим самим свій RSA ЕЦП на c_1 разом із m

$c_{ab} \equiv c_1^{d_a} \bmod n_a = 345^{41} \bmod 667 = 184.$

Будь-хто може розшифрувати $c_{ab}=184$ і отримати $c_1=345$ на публічному ключі $e_a=601$; $n_a=667$. Але лише Отримувач В може розшифрувати c_1 до отримання m на власному приватному ключі d_b .

3. Відправник А передає $c_{ab}=184$ до Отримувача В.

4. Отримувач В розшифровує $c_{ab}=184$ на публічному ключі $e_a=601$; $n_a=667$ і отримує $c_1=345$.

$c_1 \equiv c_{ab}^{e_a} \bmod n_a = 184^{601} \bmod 667 = 345.$

5. Отримувач В розшифровує $c_1=345$ на власному приватному ключі $d_b=95$ і отримує $m^*=92$.

(*Символ * означає повідомлення, отримане на приймальному боці після розшифрування*).

$m^* \equiv c_1^{d_b} \bmod n_b = 345^{95} \bmod 391 = 92.$

Завершення прикладу правильного виконання ЕЦП3.

Якщо Відправник А не зверне уваги на не однаковість модулів А та В, то може статися колізія виходу обчислюваних значень за межі наступного за протоколом модуля, що призведе до невірного результату протоколу RSA ЕЦП + конфіденційність і припинення його виконання.

ПРИКЛАД НЕВІРНОГО ВИКОНАННЯ протоколу RSA ЕЦП3.

Приклад: ЕЦП + конфіденційність повідомлення m.

ЕЦП3. Користувачі А та В, $n_a \neq n_b$:

A			B			ОІД	Напрямок
n_a	d_a	e_a	n_b	d_b	e_b	m	передачі
667	41	601	391	95	63	92	A→B

Протокол RSA ЕЦП3 при $n_a \neq n_b$:

Відправник А не порівнює n_a та n_b.

1. Він обирає випадково першим крок, що виконується за більшим модулем n_a = 667. За логікою RSA протоколу це крок постановки власного ЕЦП на m=92 на власному приватному ключі A d_a=41.

$$c_1 \equiv m^{d_a} \bmod n_a = 92^{41} \bmod 667 = 644 .$$

2. A зашифровує c_1 публічним ключем Отримувача B

$$c_{ab} \equiv c_1^{e_b} \bmod n_b = 644^{63} \bmod 391 = 161.$$

Вочевидь, c_1=644 > n_b=391 !!! Криптограма c_1 із п.1. виходить за межі наступного (за логікою Протоколу) алфавіта n_b=391. **Так виникла колізія!**

Продовжувати виконання Протоколу RSA ЕЦП3 неможливо (немає сенсу, результат буде невірним).

Покажемо це, виконавши Протокол до завершення.

3. Відправник A передає c_{ab}=161 до Отримувача B.

$$A \rightarrow c_{ab}=161 \rightarrow B.$$

4. Отримувач B розшифровує c_{ab}=161 на власному приватному ключі d_b=95 і отримує c_1=253.

$$c_1 \equiv c_{ab}\hat{}\ d_b \bmod n_b = 161\hat{}95 \bmod 391 = 253.$$

5. Отримувач B розшифровує c_1=253 на публічному ключі e_a=601 Відправника A і отримує m^*=69.

(*Символ * означає повідомлення, отримане на приймальному боці після розшифрування*).

$$m^* \equiv c_1\hat{}\ e_a \bmod n_a = 253\hat{}601 \bmod 667 = 69.$$

Вочевидь $m^* \neq m$. Помилка виконання Протоколу ЕЦП.

Завершення прикладу <u>неправильного</u> виконання Протоколу RSA ЕЦП3, ЕЦП + конфіденційність m.